ASSESSMENT TOOL II- ASSIGNMENT

COURSE CODE: ITA1409 COURSE NAME: Ethical Hacking COURSE

OUTCOME COVERED

CO1: *Apply the principle of the foundational concepts of ethical hacking, including types of hackers, ethical principles, legal frameworks, and the role of responsible disclosure in cybersecurity.*

ASSIGNMENTS QUESTIONS

Code of Conduct:

I M Prabhas (192472064) (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

1. You are asked to test the security awareness of employees by sending a phishing email that impersonates a company layoff announcement, since it's proven to get high click rates. Discuss the ethical boundaries of social engineering tests and the psychological impact on staff.

Answer:

Introduction

Social engineering tests, such as phishing simulations, are used to measure how employees behave when they receive deceptive messages. Unlike a technical penetration test, the target is a person and not a system, so the test can cause real emotional harm. In this scenario, the client wants a fake layoff announcement because fear of job loss produces a high click rate. A high click rate here, however, measures how frightened people are and says little about how security-aware they are. This answer discusses the ethical boundaries of such tests, the psychological impact on staff, and a safer approach that still meets the client's objective.

Ethical Principles Involved

The following ethical principles are relevant to this situation:

a) **Authorization:** The test must have written approval from management with the authority to give it, together with HR and Legal, and must follow a defined scope and rules of engagement.

b) **Proportionality:** The test should use only the realism needed to measure the behaviour. It should not exploit more distress than the learning objective requires.

c) **Non-maleficence:** The tester must avoid harm. Fake layoffs threaten people's livelihood, which is among the strongest workplace stressors.

d) **Confidentiality and data minimisation:** Click and credential data are personal data. They must be collected only as needed, stored securely, reported in aggregate and deleted afterwards (DPDP Act, 2023; IT Act, 2000; GDPR where applicable).

e) **Respect and no punitive use:** The purpose is education. Results must not be used to shame, rank or discipline employees.

Ethical Boundaries of Social Engineering Tests

Based on these principles, a social engineering test should stay within the following limits: it must be authorised in writing; it must avoid sensitive subjects such as job loss, health, death, financial hardship or discipline; it must have a kill switch and a debrief for everyone targeted; and it must treat people who click as learners, not as offenders. The layoff pretext crosses these boundaries because its success comes from the same fear that makes it harmful.

Psychological Impact on Staff

1. **Immediate stress:** Employees may experience anxiety, panic and sleeplessness, and may contact family or start looking for other jobs.
2. **Shame and self-blame:** Those who clicked may feel foolish, which reduces their willingness to report real incidents later.
3. **Erosion of trust:** Staff who learn that management deliberately deceived them about layoffs may doubt later genuine announcements.
4. **Rumour spread:** The fake email can be forwarded and create a real rumour of layoffs that reaches clients, media or competitors.
5. **Unequal harm:** Employees who are already vulnerable, such as sole earners, people on probation or those with anxiety, may be affected far more severely.

Publicly reported simulations that used fake bonus lures, such as GoDaddy (2020) and Tribune Publishing (2021), drew strong criticism from employees. A layoff lure is more severe, since it threatens loss instead of promising reward.

Recommended Approach

The ethical hacker should decline the layoff pretext as specified and propose a redesigned test. The steps are:

1. **Define the goal:** Agree with the client what is to be measured: click rate, credential entry or reporting behaviour.
2. **Assess harm and choose a low-harm pretext:** Suitable lures include a parcel delivery notice, a password-expiry or MFA prompt, or a shared document link. Layoff, bonus and disciplinary lures should be avoided.
3. **Obtain approval:** Get written sign-off from senior management, HR, Legal and the data-protection owner.
4. **Run under control:** Inform the helpdesk, keep a kill switch active and give instant educational feedback after a click, without blame.
5. **Report and debrief:** Report aggregated results, debrief all staff, provide targeted training and delete individual data after the agreed period.

Conclusion

A phishing simulation is justified only when its benefit clearly outweighs the harm to the people tested. A layoff-themed email fails this test, because equally useful data can be gathered with low-stakes lures that do not threaten anyone's livelihood. The ethical approach is to obtain proper authorization, keep the test proportionate, protect employee data and treat results as a basis for training, so that awareness efforts build trust in the organisation instead of damaging it.

Rubrics

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Understanding of Problem Context	20	Clearly understands the problem and accurately identifies all data handling requirements and operations	Good understanding with minor gaps	Basic understanding; some requirements unclear	Poor understanding or misinterpretation of the problem
Application of Concepts	30	Accurately applies appropriate data structures and algorithms to solve complex problems	Applies relevant concepts correctly with minor errors	Applies basic concepts with limited accuracy	Fails to apply appropriate concepts

Problem Solving Approach	20	Logical, well structured, and efficient approach	Mostly logical approach with minor gaps	Basic approach with some inconsistencies	Illogical or unclear approach
Accuracy of Solution	20	Completely correct code, output and complexity analysis with proper justification	Mostly correct with minor errors	Partially correct solution	Incorrect or incomplete solution

Criteria	**Weightage**	**Level 4 – Exemplary**	**Level 3 – Proficient**	**Level 2 – Developing**	**Level 1 – Beginning**
Clarity	10	Clear, well organized, and properly explained solution	Understandable with minor clarity issues	Limited clarity and explanation	Poorly presented and difficult to understand